

INFORMATION SECURITY MANAGEMENT SYSTEM

Information Security Manual

XYZ Corporation

Document reference	XYZ-ISMS-MAN-001
Version	1.0
Classification	Internal
Document owner	Chief Information Security Officer
Approved by	Chief Executive Officer
Effective date	31 July 2026
Next review	31 July 2027
Framework alignment	ISO/IEC 27001:2022 Annex A; AICPA SOC 2 Trust Services Criteria (Security, Availability, Confidentiality)
Applies to	All XYZ Corporation entities, personnel, contractors and third parties worldwide

Approval and Statement of Management Commitment

The Board of Directors and Executive Committee of XYZ Corporation are committed to protecting the confidentiality, integrity and availability of the information entrusted to the Company by its customers, employees, shareholders and business partners. Information security is a condition of the Company's licence to operate and a determinant of the trust on which its business depends.

This Information Security Manual is the Level 2 policy document of the Company's Information Security Management System. It is approved by the Chief Executive Officer on the recommendation of the Information Security Steering Committee, and it is mandatory for all personnel and for all third parties handling Company information.

Management commits to establishing measurable information security objectives, providing the resources necessary to achieve them, satisfying applicable legal, regulatory and contractual requirements, and continually improving the effectiveness of the management system. Compliance with this Manual is not optional, and it is not the responsibility of the security function alone; it is the responsibility of every person who handles Company information.

Approved by	Recommended by	Reviewed by
Chief Executive Officer XYZ Corporation	Chief Information Security Officer XYZ Corporation	General Counsel XYZ Corporation
Date: 31 July 2026	Date: 31 July 2026	Date: 31 July 2026

How to use this Manual

Each domain section follows a consistent structure: a control alignment panel mapping the section to ISO/IEC 27001:2022 Annex A and the SOC 2 Trust Services Criteria; purpose and scope; numbered policy statements that are mandatory requirements; supporting standards tables; step-by-step procedures; the records that must be retained as audit evidence; and the key indicators by which the domain's performance is measured. Policy statement identifiers (for example, AC-06 or BK-03) are stable and may be cited in risk registers, audit findings, exception requests and customer questionnaires.

Table of Contents

1. Introduction and Governance4

1.1 Purpose4

1.2 Scope4

1.3 Regulatory and Framework Alignment4

1.4 Information Classification5

1.5 Roles and Responsibilities5

1.6 Policy Hierarchy6

1.7 Compliance and Enforcement6

1.8 Exceptions and Risk Acceptance6

1.9 Review and Maintenance6

2. Access Control7

2.1 Purpose and Scope7

2.2 Policy Statements7

2.3 Authentication Standards8

2.4 Access Lifecycle Procedures8

2.5 Monitoring and Detection10

2.6 Records and Evidence10

2.7 Key Performance and Risk Indicators10

3. Encryption and Cryptographic Controls11

3.1 Purpose and Scope11

3.2 Policy Statements11

3.3 Approved Cryptographic Standards12

3.4 Key Management Lifecycle12

3.5 Procedures13

3.6 Records and Evidence13

3.7 Key Performance and Risk Indicators14

4. Backups15

4.1 Purpose and Scope15

4.2 Policy Statements 15

4.3 Backup Tiers 16

4.4 Procedures 16

4.5 Restore Testing Programme 17

4.6 Failure Response Timeframes 17

4.7 Records and Evidence 18

4.8 Key Performance and Risk Indicators 18

5. Incident Response 19

5.1 Purpose and Scope 19

5.2 Definitions 19

5.3 Policy Statements 19

5.4 Severity Classification 20

5.5 Response Lifecycle 20

5.6 Notification and Regulatory Reporting 22

5.7 Evidence Handling and Forensics 22

5.8 Logging and Monitoring Requirements 23

5.9 Records and Evidence 23

5.10 Key Performance and Risk Indicators 23

6. Vendor and Third-Party Security 25

6.1 Purpose and Scope 25

6.2 Policy Statements 25

6.3 Vendor Tiering and Assessment Depth 26

6.4 Assessment Domains 26

6.5 Mandatory Contractual Security Schedule 27

6.6 Procedures 27

6.7 Records and Evidence 28

6.8 Key Performance and Risk Indicators 28

7. Data Retention and Disposal 30

7.1 Purpose and Scope 30

7.2 Policy Statements 30

7.3 Baseline Retention Schedule 31

7.4 Procedures 32

7.5 Legal Hold 32

7.6 Secure Disposal Methods 33

7.7 Records and Evidence 33

7.8 Key Performance and Risk Indicators 33

8. Security Awareness and Training 35

8.1 Purpose and Scope 35

8.2 Policy Statements 35

8.3 Core Curriculum 36

8.4 Delivery Model 36

8.5 Role-Based Training Requirements 36

8.6 Phishing Simulation Programme 37

8.7 Procedures 37

8.8 Records and Evidence 38

8.9 Key Performance and Risk Indicators 38

9. Disaster Recovery and Business Continuity 39

9.1 Purpose and Scope 39

9.2 Policy Statements 39

9.3 Service Tiering and Recovery Objectives 40

9.4 Plan Content Requirements 40

9.5 Testing Programme 40

9.6 Procedures 41

9.7 Environmental and Physical Resilience 42

9.8 Records and Evidence 42

9.9 Key Performance and Risk Indicators 42

10. Assurance, Monitoring and Continual Improvement 43

10.1 Three Lines Model 43

10.2 Assurance Calendar 43

10.3 Deficiency Management 43

10.4 Reporting 43

Appendix A — Framework Control Mapping

Appendix B — Glossary

Appendix C — Document Control and Revision History

C.1 Document Control

C.2 Revision History

C.3 Related Documents

45

46

48

48

48

48

1. Introduction and Governance

1.1 Purpose

This Information Security Manual (the “Manual”) establishes the mandatory information security policies, standards and operating procedures of XYZ Corporation (“XYZ” or the “Company”). It defines how the Company protects the confidentiality, integrity and availability of information assets entrusted to it by customers, employees, business partners and regulators.

The Manual is the authoritative internal reference for the Company’s Information Security Management System (ISMS) and is the control document against which internal audit, external assurance providers and regulatory examiners assess the Company’s security posture.

1.2 Scope

This Manual applies to:

- All XYZ Corporation legal entities, subsidiaries, divisions, business units and branch locations worldwide, unless a documented exemption has been approved under Section 1.8.
- All personnel, including full-time and part-time employees, fixed-term staff, contractors, consultants, secondees, interns and temporary workers (collectively, “Personnel”).
- All third parties that store, process, transmit or access Company information or connect to Company networks, including suppliers, service providers, outsourcers, agents and joint-venture partners.
- All information assets in any form — electronic, printed, spoken or visual — and all information systems that create, process, store, transmit or dispose of them, including on-premises infrastructure, public and private cloud services, SaaS applications, endpoints, mobile devices, operational technology and removable media.
- All environments, including production, disaster recovery, pre-production, test and development.

1.3 Regulatory and Framework Alignment

The control set in this Manual is designed and maintained to satisfy, at a minimum, the following external frameworks and obligations:

Framework / Obligation	Application to XYZ Corporation
ISO/IEC 27001:2022 — ISMS requirements and Annex A controls	Certified scope. Each policy section in this Manual carries an explicit Annex A mapping. The Statement of Applicability (SoA) is maintained separately by the ISMS Manager.
AICPA SOC 2® Trust Services Criteria (2017, with 2022 revised points of focus)	Type II reporting on the Security, Availability and Confidentiality categories. Control activities in this Manual are the basis of the annual SOC 2 examination.
ISO/IEC 27002:2022	Implementation guidance for Annex A controls.
Applicable data protection law (including GDPR, UK GDPR, CCPA/CPRA and sectoral equivalents)	Governs Sections 7 (Data Retention) and 2 (Access Control) where personal data is involved. Detailed obligations are set out in the Group Privacy Policy.
Applicable financial services, sectoral and contractual security requirements	Where a regulatory, contractual or customer requirement is more stringent than this Manual, the more stringent requirement prevails and must be recorded in the applicable Control Register.

1.4 Information Classification

All controls in this Manual are applied proportionately to the classification of the information involved. XYZ Corporation operates a four-tier classification scheme:

Classification	Definition	Illustrative Examples
Restricted	Unauthorised disclosure would cause severe harm to the Company, its customers or individuals, or constitute a reportable regulatory breach.	Customer financial records, authentication secrets, cryptographic keys, special-category personal data, merger and acquisition material.
Confidential	Unauthorised disclosure would cause material harm to the Company or its counterparties.	Contracts, pricing models, source code, internal audit reports, standard personal data of employees and customers.
Internal	Intended for internal use; disclosure would cause limited harm.	Internal procedures, org charts, project plans, non-sensitive internal correspondence.
Public	Approved for public release.	Published financial statements, marketing material, public website content.

Where this Manual specifies a control for “Restricted and Confidential” information, that control is mandatory. Application to Internal information is recommended unless otherwise stated.

1.5 Roles and Responsibilities

Role	Information Security Accountabilities
Board of Directors / Risk Committee	Approves the Company’s information security risk appetite; receives quarterly reporting on security risk, incidents and programme status; approves material risk acceptances.
Chief Executive Officer	Ultimately accountable for information security. Approves this Manual.
Chief Information Security Officer (CISO)	Owns this Manual and the ISMS. Sets security strategy and standards, operates the security function, reports to the Risk Committee, and has authority to require remediation of identified deficiencies.
Information Security Steering Committee	Cross-functional forum chaired by the CISO. Meets at least quarterly. Reviews risk register, policy exceptions, incident trends, programme roadmap and control effectiveness.
ISMS Manager	Maintains the Statement of Applicability, risk register, internal audit programme, management review records and evidence repository.
Chief Information Officer / Head of IT	Accountable for the secure design, build and operation of infrastructure, platforms and end-user computing.
Information Asset Owners	Named senior business owners accountable for the classification of their information, approval of access, and definition of availability and retention requirements.
System Owners	Accountable for the security configuration, patching, monitoring and lifecycle of individual systems.
Data Protection Officer / Privacy Counsel	Advises on personal data obligations; co-owns Sections 7.4 and 7.5; assesses regulatory notification duties during incidents.
Internal Audit	Provides independent assurance over the design and operating effectiveness of controls in this Manual. Reports functionally to the Audit Committee.
Line Managers	Ensure Personnel complete required training, hold only necessary access, and comply with this Manual.

Role	Information Security Accountabilities
All Personnel	Comply with this Manual, complete assigned training, protect credentials and report suspected security events without delay.

1.6 Policy Hierarchy

This Manual sits within a four-level documentation hierarchy. Each level must be consistent with the level above it:

- 1. **Level 1 — Information Security Policy.** The Board-approved statement of intent and risk appetite.
- 2. **Level 2 — This Manual.** Mandatory policy statements and governing procedures by domain.
- 3. **Level 3 — Technical Standards and Baselines.** Platform-specific configuration standards (for example, the Linux Hardening Standard, the Cloud Security Baseline, the Cryptographic Standard).
- 4. **Level 4 — Work Instructions and Runbooks.** Step-by-step operational procedures maintained by delivery teams.

1.7 Compliance and Enforcement

Compliance with this Manual is a condition of employment and of engagement for all third parties. Violations may result in disciplinary action up to and including dismissal, termination of contract, and referral to law enforcement or the relevant regulator. Deliberate circumvention of a security control is treated as gross misconduct.

Control effectiveness is verified through continuous automated control monitoring, quarterly control self-assessment by control owners, the annual internal audit plan, the annual SOC 2 Type II examination, and the ISO 27001 surveillance and recertification audit cycle.

1.8 Exceptions and Risk Acceptance

Any deviation from this Manual requires a formal, time-bound exception recorded in the Policy Exception Register. Exception requests must document the requirement being waived, the business justification, the residual risk, compensating controls, an owner and an expiry date.

Residual Risk Rating	Approval Authority	Maximum Duration
Low	CISO delegate (Head of Security Governance)	12 months
Medium	CISO	12 months
High	CISO and the accountable Executive Committee member	6 months
Critical	Risk Committee of the Board	3 months

Exceptions may not be renewed more than once without escalation to the next approval tier. All open exceptions are reported to the Information Security Steering Committee quarterly. An expired exception constitutes a control failure and is logged as such.

1.9 Review and Maintenance

This Manual is reviewed and re-approved at least annually by the CISO, and additionally following any material organisational change, significant security incident, adverse audit finding, or change in applicable law or contractual obligation. All changes are version-controlled and recorded in Appendix C.

2. Access Control

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.5.3 Segregation of duties; A.5.15 Access control; A.5.16 Identity management; A.5.17 Authentication information; A.5.18 Access rights; A.8.2 Privileged access rights; A.8.3 Information access restriction; A.8.4 Access to source code; A.8.5 Secure authentication; A.8.18 Use of privileged utility programs
SOC 2 Trust Services Criteria	CC6.1, CC6.2, CC6.3, CC6.6, CC6.8; CC5.2

2.1 Purpose and Scope

This section governs how identities are established, how access to Company information and systems is authorised, provisioned, authenticated, monitored and revoked. It applies to all human and non-human (service, machine and application) identities across all environments.

2.2 Policy Statements

- AC-01 — Least privilege.** Access is granted only to the information and system functions required to perform a defined job role. Default access is no access.
- AC-02 — Need to know.** Access to Restricted and Confidential information requires a documented business need approved by the Information Asset Owner.
- AC-03 — Unique identity.** Every user is issued a unique identifier. Shared, generic and anonymous accounts are prohibited except where an approved exception exists under Section 1.8; where permitted, use must be attributable through a credential-vaulting or session-brokering solution.
- AC-04 — Role-based access.** Entitlements are grouped into roles defined against the job architecture. Direct assignment of individual entitlements to users is prohibited for in-scope systems.
- AC-05 — Segregation of duties.** Conflicting duties are separated so that no single individual can initiate, approve and execute a material transaction or change unilaterally. Where segregation is not technically feasible, compensating detective controls must be implemented and documented.
- AC-06 — Multi-factor authentication.** Phishing-resistant MFA is mandatory for all remote access, all administrative and privileged access, all access to Restricted information, and all access to internet-facing and cloud management planes. FIDO2/WebAuthn hardware authenticators or platform passkeys are the approved factors; SMS and voice one-time passcodes are prohibited for privileged access.
- AC-07 — Privileged access management.** Privileged credentials must be vaulted, rotated automatically and issued just-in-time for a bounded period against an approved ticket. Standing administrative access is prohibited. Privileged sessions must be recorded.
- AC-08 — Separation of duties for identity administration.** Identity administrators may not approve their own access requests, and access approval must be performed by a party independent of provisioning.
- AC-09 — Non-human identities.** Service accounts, API keys, tokens and workload identities must have a named human owner, a documented purpose, scoped permissions, an expiry date, and automated rotation. Interactive logon must be disabled for service accounts.
- AC-10 — Remote and network access.** All remote access to the corporate environment is brokered through a Zero Trust access service enforcing device posture, identity and context. Split tunnelling to Restricted environments is prohibited.

AC-11 — Session controls. Interactive sessions must lock after 15 minutes of inactivity and terminate after 12 hours. Privileged sessions terminate after 4 hours. Concurrent administrative sessions from distinct geographies are blocked and alerted.

AC-12 — Source code and build systems. Write access to source repositories, build pipelines and artefact registries is restricted, requires MFA, and enforces peer review before merge to protected branches. Pipeline secrets must be sourced from the secrets manager, never from repository files.

AC-13 — Physical access. Physical access to facilities housing information processing equipment is controlled by badge, logged, and reviewed quarterly. Data centre and secure area access additionally requires escort or a second authorisation factor.

2.3 Authentication Standards

Requirement	Standard User	Privileged / Administrative	Non-Human Identity
Primary factor	SSO via corporate IdP	SSO via corporate IdP	Certificate or workload identity federation
Second factor	FIDO2 / passkey required	FIDO2 hardware key required	Not applicable
Passwords (where unavoidable)	Minimum 14 characters, screened against breach corpus, no forced periodic expiry	Minimum 20 characters, vaulted, rotated on each use	Minimum 32 characters, machine-generated, rotated at most every 90 days
Lockout	10 failed attempts, 30-minute lockout	5 failed attempts, manual unlock	Alert and disable on anomalous use
Credential storage	Salted, memory-hard hash (Argon2id or bcrypt cost ≥ 12)	Privileged access management vault	Managed secrets service with envelope encryption
Maximum credential lifetime	N/A (passwordless preferred)	8 hours (just-in-time)	90 days

2.4 Access Lifecycle Procedures

2.4.1 Joiners — Provisioning

- Human Resources creates the worker record in the HR system of record; this record is the authoritative source of identity.
- The identity platform automatically provisions the unique account and baseline birthright entitlements derived from the worker's job role, department and location.
- Any entitlement beyond birthright access must be requested through the Identity Governance platform by the line manager and approved by the Information Asset Owner. Segregation-of-duties conflicts are evaluated automatically at request time and block submission where a toxic combination is detected.
- Access must not be granted before the background screening required by Section 8.3 has cleared and the Acceptable Use Agreement has been signed.
- Provisioning is completed within one business day of approval. Manual provisioning outside the Identity Governance platform is prohibited.

2.4.2 Movers — Role Change

- HR records the role, department or location change and the identity platform triggers a mover event within 24 hours.

2. Birthright entitlements are recalculated automatically; entitlements associated with the previous role are revoked.
3. Retained non-birthright entitlements require positive re-approval by the receiving line manager within 10 business days. Entitlements not re-approved within that window are revoked automatically.
4. Privileged roles are always revoked on a mover event and must be re-requested.

2.4.3 Leavers — Deprovisioning

1. HR records the termination in the system of record. For voluntary departures the record is created at notice; for involuntary departures HR notifies the Security Operations Centre in advance so that revocation can be timed to the notification meeting.
2. All interactive access, sessions and tokens are revoked within four hours of the effective termination time. Privileged access, remote access and physical badge access are revoked immediately.
3. Devices, tokens, badges and removable media are recovered and logged; unrecovered assets are remotely wiped and reported as an incident.
4. Mailbox and file shares are transferred to the line manager under a documented handover, retained per Section 7, and then disposed of.
5. The Identity Governance platform produces a deprovisioning completion certificate. Exceptions are escalated to the CISO within 24 hours.

2.4.4 Access Reviews (Recertification)

Access Population	Frequency	Reviewer	Completion SLA
Privileged and administrative accounts	Monthly	System Owner, countersigned by CISO delegate	10 business days
Access to Restricted information	Quarterly	Information Asset Owner	15 business days
Access to Confidential information and general application access	Semi-annually	Line manager and Application Owner	20 business days
Non-human identities and API keys	Quarterly	Named identity owner	15 business days
Third-party and contractor access	Quarterly	Contract Owner	10 business days
Physical access to secure areas	Quarterly	Facilities Security Manager	15 business days

Reviewers must positively confirm each entitlement; bulk approval without individual review is prohibited and is detected by the Identity Governance platform. Revocations identified during review are executed within five business days. Reviews not completed within the SLA are escalated to the reviewer's manager after five days and to the Steering Committee after ten.

2.4.5 Emergency (Break-Glass) Access

1. Break-glass accounts exist only where loss of the identity provider would otherwise prevent recovery. They are documented, limited in number, and excluded from routine automation.
2. Credentials are held in split custody in a sealed physical safe or a segregated vault requiring dual control to open.
3. Any use generates an immediate high-severity alert to the Security Operations Centre and the CISO.
4. Use must be justified in writing within 24 hours, all session activity reviewed, and the credential rotated before the account is returned to standby.
5. Break-glass accounts are tested semi-annually to confirm they function, and the test is treated as a use event for review purposes.

2.5 Monitoring and Detection

- All authentication events, authorisation failures, privilege escalations, and identity object changes are forwarded to the central log platform within 15 minutes and retained per Section 7.3.
- The Security Operations Centre maintains detection content for impossible-travel logins, MFA fatigue and push-bombing patterns, dormant account reactivation, privileged group membership changes, creation of new federation trusts, and mass entitlement changes.
- Accounts inactive for 45 consecutive days are automatically disabled; accounts inactive for 90 days are deleted subject to retention obligations.

2.6 Records and Evidence

- Access request, approval and provisioning records — retained 7 years.
- Access review campaign results, including reviewer attestations and revocation evidence — retained 7 years.
- Joiner, mover and leaver completion certificates — retained 7 years.
- Break-glass use justifications and session recordings — retained 7 years.
- Policy exceptions relating to access control — retained 7 years after expiry.

2.7 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Leaver access revoked within 4 hours	≥ 99%	< 97%
Access review campaigns completed within SLA	100%	< 95%
Privileged accounts with standing access	0	> 0
Accounts without MFA enrolled	0	> 0
Non-human identities without a named owner	0	> 2%
Segregation-of-duties conflicts open beyond 30 days	0	> 0

3. Encryption and Cryptographic Controls

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.8.24 Use of cryptography; A.5.17 Authentication information; A.5.33 Protection of records; A.8.12 Data leakage prevention; A.8.20 Networks security; A.8.21 Security of network services; A.8.26 Application security requirements; A.7.10 Storage media
SOC 2 Trust Services Criteria	CC6.1, CC6.6, CC6.7; C1.1

3.1 Purpose and Scope

This section defines the mandatory use of cryptography to protect Company and customer information, and the lifecycle management of cryptographic keys. It applies to data at rest, data in transit, data in use where supported, and to all key material regardless of where it is generated or stored.

3.2 Policy Statements

- EN-01 — Approved algorithms only.** Only algorithms, modes, key lengths and protocol versions listed in the XYZ Cryptographic Standard (Level 3 document) may be used. Proprietary, unpublished or self-developed cryptographic algorithms are prohibited.
- EN-02 — Validated implementations.** Cryptographic functions must be provided by FIPS 140-3 (or FIPS 140-2, until sunset) validated modules or by the equivalent validated cryptographic services of an approved cloud provider. Application developers must not implement primitives directly.
- EN-03 — Encryption at rest.** All Restricted and Confidential information must be encrypted at rest using AES-256 or equivalent. This applies to databases, object and block storage, backups, archives, message queues, search indexes, log stores, endpoints and removable media.
- EN-04 — Encryption in transit.** All information in transit across any network, including internal networks, must be protected with TLS 1.2 or higher using approved cipher suites, with TLS 1.3 required for all new and internet-facing services. Unencrypted protocols (HTTP, FTP, Telnet, SNMPv1/v2c, SMBv1, LDAP without TLS) are prohibited.
- EN-05 — Full-disk encryption.** All laptops, desktops, mobile devices and removable media are encrypted at rest with centrally escrowed recovery keys. Devices that cannot be encrypted may not store Company information.
- EN-06 — Key separation.** Keys used to protect data must be logically and physically separated from the data they protect. Encryption keys must never be stored in source code, configuration files, container images, environment variables of shared systems, or unencrypted backups.
- EN-07 — Hardware protection of root keys.** Root and key-encryption keys must be generated and stored within a hardware security module (HSM) or a cloud key management service backed by validated HSMs, and must not be exportable in plaintext.
- EN-08 — Dual control and split knowledge.** Manual operations on root key material require dual control by two authorised custodians, with split knowledge such that no single custodian can reconstruct the key.
- EN-09 — Certificate management.** All X.509 certificates must be issued from an approved certificate authority, inventoried in the central certificate management platform, and automatically renewed. Self-signed certificates are prohibited in production. Wildcard certificates require CISO approval.
- EN-10 — Customer-managed keys.** Where a customer contract requires customer-managed or customer-supplied keys, the arrangement must be documented, the key hierarchy segregated per tenant,

and the operational impact of key revocation defined and tested.

EN-11 — Cryptographic agility and post-quantum readiness. Systems must be designed so that algorithms can be replaced without redesign. The CISO maintains a cryptographic inventory and a migration roadmap to NIST-standardised post-quantum algorithms, prioritising long-lived Restricted data exposed to harvest-now-decrypt-later risk.

EN-12 — Legal constraints. Use, import and export of cryptography must comply with the law of every jurisdiction in which the Company operates. Legal Counsel must be consulted before deploying cryptography in a new jurisdiction.

3.3 Approved Cryptographic Standards

Use Case	Approved	Prohibited / Deprecated
Symmetric encryption	AES-256-GCM; AES-256-CBC with HMAC-SHA-256; ChaCha20-Poly1305	DES, 3DES, RC4, Blowfish, AES-ECB, any unauthenticated mode
Asymmetric encryption / key exchange	RSA $\geq$ 3072-bit; ECDH / ECDSA with P-256, P-384 or Curve25519	RSA $<$ 2048-bit; DSA; static Diffie-Hellman $<$ 2048-bit
Hashing	SHA-256, SHA-384, SHA-512, SHA-3	MD5, SHA-1 (except in legacy signature verification with documented exception)
Password storage	Argon2id (preferred); scrypt; bcrypt cost $\geq$ 12; PBKDF2-HMAC-SHA-256 with $\geq$ 600,000 iterations	Unsalted hashes; single-round hashing; reversible encryption of passwords
Transport	TLS 1.3 (required for new services); TLS 1.2 with forward-secret AEAD suites	SSL 2.0/3.0, TLS 1.0/1.1, NULL and EXPORT cipher suites, RC4 suites
Random number generation	Platform CSPRNG seeded from a hardware entropy source	Non-cryptographic pseudorandom functions
Digital signatures	RSA-PSS $\geq$ 3072-bit; ECDSA P-256 or above; Ed25519	RSA PKCS#1 v1.5 for new designs; SHA-1 based signatures

3.4 Key Management Lifecycle

Phase	Mandatory Requirements
Generation	Keys generated inside an HSM or validated KMS using an approved CSPRNG. Key strength appropriate to the classification and required protection lifetime.
Distribution	Keys are never transmitted in plaintext. Distribution occurs through the KMS API, a key-wrapping mechanism, or dual-control manual procedures for HSM master keys.
Storage	Data-encryption keys are wrapped by key-encryption keys, which are wrapped by root keys held in HSM. Root keys are non-exportable.
Use	Access to key operations is authorised through IAM policy, logged individually, and subject to the privileged access controls in Section 2.
Rotation	Data-encryption keys rotated at least annually; key-encryption keys at least every two years; TLS certificates at most every 90 days (automated); signing keys per the Cryptographic Standard. Rotation is automated wherever the platform supports it.
Archival	Retired keys are retained in escrow only for as long as encrypted data protected by them must remain readable, and are marked as decrypt-only.

Phase	Mandatory Requirements
Revocation and destruction	Compromised or suspected-compromised keys are revoked immediately and treated as a security incident under Section 5. Destruction requires dual control, an authorised destruction certificate, and confirmation that no retained data depends on the key.
Compromise response	Immediate revocation; re-encryption of affected data under a new key; assessment of data exposure; notification assessment under Section 5.6.

3.5 Procedures

3.5.1 Deploying a New Cryptographic Implementation

1. The System Owner submits a cryptographic design to the Security Architecture function, identifying the data classification, threat model, algorithms, key hierarchy, rotation approach and cryptoperiod.
2. Security Architecture reviews against the Cryptographic Standard and either approves, approves with conditions, or rejects. Approval is recorded in the cryptographic inventory.
3. Implementation is validated by automated scanning (TLS configuration scanning, secret detection, dependency analysis) and by penetration testing before production release.
4. The System Owner registers all keys and certificates in the certificate and key inventory with owner, cryptoperiod and rotation method.

3.5.2 Key Rotation

1. The KMS emits a rotation-due event 30 days before cryptoperiod expiry to the named key owner and to the Security Operations Centre.
2. Automated rotation executes in a change window under the Change Management Standard; the previous key version is retained in decrypt-only state.
3. For keys requiring re-encryption, the owner schedules and monitors the re-encryption job and confirms completion before retiring the prior key version.
4. Failure to rotate within the cryptoperiod is a control failure, raised as a finding and escalated to the CISO if unresolved after 15 days.

3.5.3 Certificate Expiry Prevention

1. All certificates are enrolled in automated renewal (ACME or equivalent) at issuance. Manual certificates require an exception.
2. The certificate platform alerts owners at 45, 30, 14 and 7 days before expiry, and pages the on-call engineer at 3 days.
3. Externally facing certificate expiry is monitored independently by external synthetic monitoring as a detective backstop.

3.6 Records and Evidence

- Cryptographic inventory, including algorithm, key length, owner and cryptoperiod — maintained continuously, versions retained 7 years.
- Key generation, rotation, revocation and destruction certificates — retained 7 years after key destruction.
- Key custodian appointment and acknowledgement records — retained 7 years.
- HSM audit logs — retained 7 years.
- TLS configuration scan results — retained 3 years.

3.7 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Restricted data stores encrypted at rest	100%	< 100%
External endpoints scoring A or above on TLS configuration scan	100%	< 98%
Certificates expiring without renewal	0	> 0
Keys past cryptoperiod	0	> 0
Secrets detected in source repositories	0	> 0
Systems using deprecated algorithms	0	> 0 without exception

4. Backups

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.8.13 Information backup; A.8.14 Redundancy of information processing facilities; A.5.33 Protection of records; A.5.29 Information security during disruption; A.7.10 Storage media; A.8.24 Use of cryptography
SOC 2 Trust Services Criteria	A1.2, A1.3; CC7.5; C1.1

4.1 Purpose and Scope

This section defines how the Company creates, protects, tests and restores backup copies of information and systems so that data can be recovered following accidental deletion, corruption, hardware failure, ransomware or site loss. It applies to all production systems and to any non-production system holding Restricted or Confidential information.

Backups are a data-recovery control. They are related to, but distinct from, the disaster recovery capability defined in Section 9; a valid backup is a prerequisite for, but not a substitute for, a tested recovery plan.

4.2 Policy Statements

- BK-01 — Mandatory backup.** Every production system and every information asset classified Internal or above must have a defined backup schedule recorded in the Backup Register, derived from the asset's Recovery Point Objective (RPO).
- BK-02 — 3-2-1-1-0 rule.** The Company maintains at least three copies of critical data, on at least two distinct media or storage technologies, with at least one copy off-site in a separate failure domain, at least one copy immutable or air-gapped, and zero errors verified through restore testing.
- BK-03 — Immutability.** Backups of Restricted and Confidential information must be written to immutable, write-once storage with an object-lock retention period that cannot be shortened by any operational account, including administrators. Deletion before lock expiry requires dual-control approval by the CISO and the Head of Infrastructure.
- BK-04 — Isolation from production identity.** The backup environment must use a separate identity domain and separate credentials from production. Compromise of a production administrative account must not confer the ability to delete, encrypt or alter backups.
- BK-05 — Encryption.** All backups are encrypted at rest and in transit in accordance with Section 3. Backup encryption keys are managed independently of production data keys and are recoverable in a disaster scenario without dependence on the failed environment.
- BK-06 — Restore testing.** Restore capability must be tested on a defined schedule (Section 4.5). A backup that has not been successfully restore-tested within its defined interval is not considered a valid backup.
- BK-07 — Monitoring.** Every backup job must be monitored. Failed, partial and skipped jobs generate alerts to the responsible operations team and must be remediated within the timeframes in Section 4.6.
- BK-08 — Retention alignment.** Backup retention periods must be defined to satisfy operational recovery needs while remaining consistent with the retention and deletion obligations in Section 7. Indefinite backup retention is prohibited.
- BK-09 — Physical media.** Where removable media is used, it must be encrypted, inventoried, transported by an approved bonded courier under chain of custody, stored in an access-controlled off-site facility, and securely destroyed at end of life per Section 7.6.

BK-10 — SaaS and cloud data. Data held in third-party SaaS platforms is subject to the same backup requirements. Reliance on a vendor's native replication or recycle bin does not satisfy this policy unless the vendor contractually provides point-in-time restore meeting the asset's RPO, verified under Section 6.

BK-11 — Access control. Backup administration is a privileged function subject to Section 2.2 AC-07. Restore operations affecting production data require change approval and are logged.

BK-12 — Confidentiality of restored data. Data restored into a non-production environment must be masked, tokenised or subsetting before use, unless an exception is approved and the environment is controlled to production standard.

4.3 Backup Tiers

Systems are assigned a backup tier by the Information Asset Owner based on business criticality, agreed with the CIO and recorded in the Backup Register.

Tier	System Profile	RPO	Backup Schedule	Retention
Tier 0 — Mission critical	Customer-facing transaction platforms; systems where data loss is a regulatory or contractual breach	≤ 15 minutes	Continuous replication plus transaction log shipping; full daily; synthetic full weekly	35 daily, 12 monthly, 7 annual
Tier 1 — Business critical	Core internal platforms; finance, HR and ERP systems	≤ 4 hours	Incremental every 4 hours; full daily	35 daily, 12 monthly, 7 annual
Tier 2 — Business important	Departmental applications; collaboration and file services	≤ 24 hours	Incremental daily; full weekly	30 daily, 12 monthly
Tier 3 — Standard	Non-critical internal tooling; development and test systems	≤ 7 days	Full weekly	8 weekly

Where a system is subject to a legal hold under Section 7.7, backup retention is suspended from deletion until the hold is released, irrespective of the tier schedule.

4.4 Procedures

4.4.1 Onboarding a System to Backup

1. The System Owner registers the system in the Backup Register at the point of production readiness review, specifying data classification, tier, RPO, RTO and any regulatory retention driver.
2. Infrastructure Operations configures backup policy from the tier template. Deviations require CISO and CIO approval.
3. An initial full backup is taken and a validation restore is performed to a sandbox before the system is accepted into production. Production go-live is blocked until the validation restore succeeds.
4. The system is added to backup monitoring dashboards and to the restore-test rotation.

4.4.2 Daily Backup Operations

1. Backup jobs execute automatically per schedule. The backup platform verifies checksum integrity of each written object.
2. Operations reviews the daily backup dashboard by 09:00 local time, confirming all scheduled jobs completed and reconciling job count against the Backup Register.
3. Any failed or partial job raises a ticket automatically with the severity in Section 4.6.
4. Backup success rates, capacity trends and job durations are reported monthly to the CIO and quarterly to the Steering Committee.

4.4.3 Performing a Restore

1. The requester raises a restore request specifying the system, the recovery point, the target environment and the business justification.
2. The System Owner approves. Restores of Restricted data, and any restore into production, additionally require Change Advisory Board approval; emergency restores may proceed under the emergency change procedure with retrospective approval within 24 hours.
3. Operations performs the restore, records start and completion times, and captures the achieved recovery point.
4. The requester validates data integrity and confirms acceptance in writing. Discrepancies are escalated as a potential integrity incident under Section 5.
5. Where the restore was in response to an incident, the restore record is attached to the incident record and the actual RPO and RTO achieved are compared to target.

4.4.4 Ransomware-Resilient Recovery

1. Recovery from a destructive attack must use the immutable copy. Before restoring, the Incident Commander must confirm the selected recovery point precedes the earliest evidence of compromise, based on forensic timeline analysis.
2. Restored systems are rebuilt from known-good images into a clean, isolated recovery network, not into the compromised environment.
3. Restored data is scanned for malware and for indicators of compromise before the environment is reconnected.
4. Credentials, keys and tokens in scope of the compromise are rotated before service resumption, per Sections 2 and 3.

4.5 Restore Testing Programme

Test Type	Scope	Frequency	Success Criteria
Automated integrity verification	All backup sets	Every backup job	Checksum and catalogue verification pass
Sample file / object restore	Random sample across all tiers	Weekly	Restored object matches source hash
Full system restore	Rotating selection covering every Tier 0 and Tier 1 system at least annually	Monthly	System restored to a working state within RTO; data consistent to target RPO
Application-consistent database restore	All Tier 0 databases	Quarterly	Database opens without repair; referential integrity checks pass
Isolated clean-room recovery	Tier 0 estate	Annually	Full recovery from immutable copy into an isolated environment without production dependencies

Every test produces a report recording scope, achieved RPO and RTO, deviations, defects and remediation actions with owners and due dates. Test reports are retained as SOC 2 and ISO 27001 evidence. A failed test is a control failure and must be re-tested successfully within 30 days.

4.6 Failure Response Timeframes

Condition	Severity	Remediation SLA
Tier 0 backup job failure	High	Investigate within 1 hour; successful backup within 8 hours
Tier 1 backup job failure	Medium	Investigate within 4 hours; successful backup within 24 hours
Tier 2 or 3 backup job failure	Low	Successful backup within 72 hours
Two consecutive failures on any tier	High	Escalate to Head of Infrastructure; daily reporting until resolved
Restore test failure	High	Root cause within 5 business days; successful re-test within 30 days
Immutability or isolation control failure	Critical	Immediate escalation to CISO; treated as a security incident under Section 5

4.7 Records and Evidence

- Backup Register, including tier, RPO, schedule and retention per system — maintained continuously.
- Backup job logs and success/failure records — retained 3 years.
- Restore request, approval and completion records — retained 7 years.
- Restore test reports — retained 7 years.
- Off-site media chain-of-custody and destruction certificates — retained 7 years.

4.8 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Backup job success rate (Tier 0 and 1)	≥ 99.5%	< 99%
Production systems in the Backup Register	100%	< 100%
Tier 0 systems with a successful restore test in the last 12 months	100%	< 100%
Tier 0/1 backup sets held immutably	100%	< 100%
Mean time to restore (Tier 0 sample restore)	Within stated RTO	Exceeds RTO
Backup sets past defined retention and not deleted	0	> 0

5. Incident Response

CONTROL ALIGNMENT

ISO/IEC 27001:2022 Annex A

A.5.24 Incident management planning and preparation; A.5.25 Assessment and decision on events; A.5.26 Response to incidents; A.5.27 Learning from incidents; A.5.28 Collection of evidence; A.6.8 Event reporting; A.5.5 Contact with authorities; A.5.6 Contact with special interest groups; A.8.15 Logging; A.8.16 Monitoring activities

SOC 2 Trust Services Criteria

CC7.1, CC7.2, CC7.3, CC7.4, CC7.5; CC2.2, CC2.3; CC4.2

5.1 Purpose and Scope

This section establishes how XYZ Corporation prepares for, detects, triages, contains, eradicates and recovers from information security incidents, and how it learns from them. It applies to all security events affecting Company or customer information, regardless of whether the affected system is operated by the Company or by a third party.

5.2 Definitions

Term	Definition
Security event	Any observable occurrence relevant to information security, including alerts, anomalies and user reports. Most events are benign.
Security incident	One or more events that compromise, or credibly threaten to compromise, the confidentiality, integrity or availability of information or systems.
Major incident	A Severity 1 or Severity 2 incident, or any incident likely to require regulatory notification, customer notification or public disclosure.
Personal data breach	A security incident leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data.
Near miss	An event where a control failure occurred but harm was prevented by another control or by chance. Near misses are recorded and reviewed.

5.3 Policy Statements

IR-01 — Duty to report. All Personnel and third parties must report suspected security events immediately, and in any case within one hour of becoming aware, to the Security Operations Centre through the published channels. Failure to report, or delay in reporting, is a disciplinary matter.

IR-02 — No-blame reporting. Personnel who report an event in good faith, including one they caused, will not be penalised for the act of reporting. This protection does not extend to deliberate malicious acts or to concealment.

IR-03 — Single point of coordination. Every incident has one named Incident Commander with the authority to direct response activity across all functions, including authority to disconnect systems and suspend business processes.

IR-04 — 24x7 capability. The Company maintains a 24x7 monitoring and response capability with a documented on-call rota and defined escalation paths.

IR-05 — Evidence preservation. Volatile and persistent evidence must be preserved before remediation wherever it does not materially delay containment. Chain of custody must be maintained for all evidence.

IR-06 — Privilege. Where litigation or regulatory action is reasonably anticipated, the investigation is conducted at the direction of Legal Counsel to preserve legal privilege. Personnel must not speculate about cause or liability in written communications.

IR-07 — Notification obligations. Regulatory, contractual and customer notification obligations are assessed by Legal Counsel and the Data Protection Officer at the earliest opportunity and tracked against statutory deadlines, including the 72-hour supervisory authority deadline where GDPR applies.

IR-08 — External communication control. Only the Chief Communications Officer, or a delegate authorised by the Crisis Management Team, may communicate about an incident externally. All Personnel must direct media, customer and regulator enquiries to that function.

IR-09 — Third-party incidents. Incidents at suppliers that affect Company information are managed under this section, with the Contract Owner accountable for obtaining information from the supplier under the contractual obligations in Section 6.

IR-10 — Post-incident review. Every Severity 1 and Severity 2 incident requires a blameless post-incident review within 10 business days, producing corrective actions with named owners and due dates, tracked to closure.

IR-11 — Testing. The incident response plan is exercised at least twice annually, including at least one Board-level or executive crisis simulation and one technical tabletop or purple-team exercise.

IR-12 — No unauthorised counter-attack. Offensive action against a suspected attacker's infrastructure is prohibited.

5.4 Severity Classification

Severity	Criteria	Initial Response	Notification
SEV 1 — Critical	Confirmed compromise of Restricted data; ransomware or destructive attack; complete outage of a Tier 0 service; confirmed large-scale personal data breach	Immediate; Incident Commander engaged within 15 minutes; war room stood up	CEO, CISO, General Counsel, Board Risk Committee Chair, Crisis Management Team — within 1 hour
SEV 2 — High	Suspected compromise of Restricted data; confirmed compromise of Confidential data; compromise of a privileged account; material Tier 0/1 degradation	Incident Commander engaged within 30 minutes	CISO, CIO, General Counsel, affected Executive — within 2 hours
SEV 3 — Medium	Contained malware on an endpoint; isolated policy violation; unsuccessful targeted attack; single-user credential compromise with no data access	Assigned within 2 hours during business hours	Security Operations Manager; summarised in weekly report
SEV 4 — Low	Commodity phishing reported and blocked; minor misconfiguration with no exposure; near miss	Assigned within 1 business day	Logged and trended; no individual escalation

Severity is assigned at triage and reassessed continuously. Severity may only be downgraded by the Incident Commander with a documented rationale.

5.5 Response Lifecycle

5.5.1 Phase 1 — Preparation

- Maintain and annually review the Incident Response Plan, severity matrix, contact tree, escalation paths and communication templates.

- Maintain the on-call rota, out-of-band communication channel (independent of corporate email and chat), and a pre-authorised retainer with an external digital forensics and incident response (DFIR) firm.
- Maintain forensic tooling, a clean-room investigation environment, and pre-staged golden images for rebuild.
- Maintain relationships with law enforcement, the national CERT and sector information-sharing bodies, and confirm cyber insurance notification requirements annually.
- Ensure logging coverage and retention meet the requirements in Section 5.8.

5.5.2 Phase 2 — Detection and Reporting

1. Events are detected by SIEM correlation, EDR, cloud security posture monitoring, data loss prevention, fraud monitoring, threat intelligence, user reports, customer reports or third-party notification.
2. All events are logged in the incident management system with a unique identifier, detection source, timestamp and initial description.
3. The Security Operations Centre acknowledges all detections within 15 minutes for high-fidelity alerts and 1 hour otherwise.

5.5.3 Phase 3 — Triage and Analysis

1. The analyst validates the event, determines whether it constitutes an incident, and assigns an initial severity.
2. For SEV 1 and SEV 2, an Incident Commander is appointed and the response team is assembled, drawing on Security Operations, Infrastructure, Application Engineering, Legal, Privacy, Communications, HR and the relevant business owner as required.
3. The team establishes scope: affected systems, accounts, data classifications, data volumes, data subjects, time window and attack path.
4. A running incident timeline is maintained from the outset. All actions, decisions and their rationale are recorded contemporaneously.

5.5.4 Phase 4 — Containment

1. Short-term containment isolates affected systems, disables compromised accounts, revokes sessions and tokens, blocks indicators at the network and identity layers, and preserves volatile evidence (memory, network state) before shutdown where feasible.
2. The Incident Commander explicitly weighs the trade-off between rapid containment and evidence preservation, and records the decision.
3. Long-term containment applies temporary controls that allow safe continuation of business operations while eradication is planned.
4. Containment actions taken under emergency authority are documented and retrospectively approved through change management within 24 hours.

5.5.5 Phase 5 — Eradication

1. Determine and address root cause, including the initial access vector and any persistence mechanisms.
2. Rebuild compromised systems from known-good images rather than cleaning in place, unless rebuild is technically infeasible and an exception is approved by the Incident Commander.
3. Rotate all credentials, keys, certificates and tokens within the blast radius, per Sections 2 and 3.
4. Remediate the exploited vulnerability or misconfiguration across the estate, not only on the affected system.

5.5.6 Phase 6 — Recovery

1. Restore service from validated backups per Section 4.4.4, or from rebuilt systems, into a clean environment.
2. Apply enhanced monitoring to recovered systems for a minimum of 30 days, with detection content tuned to the observed adversary behaviour.
3. The Incident Commander, with the business owner, formally authorises return to normal operations against defined exit criteria.
4. Confirm data integrity and completeness with the business owner before closing the recovery phase.

5.5.7 Phase 7 — Post-Incident Review and Learning

1. Hold a blameless post-incident review within 10 business days of resolution, chaired by a facilitator independent of the response.
2. The review covers the incident timeline, what worked, what did not, detection and response times against target, control failures, and near misses.
3. Corrective and preventive actions are recorded with owners, priorities and due dates, and tracked in the risk and issue register to closure. Actions from SEV 1 incidents are reported to the Steering Committee monthly until closed.
4. Lessons are fed back into detection content, runbooks, training, the risk register and this Manual.
5. The incident record is closed only when all mandatory actions are complete or formally re-baselined with approval.

5.6 Notification and Regulatory Reporting

Stakeholder	Trigger	Deadline	Owner
Executive and Board	SEV 1, or SEV 2 with escalation potential	Within 1 hour of severity assignment	CISO
Cyber insurer	Any incident with potential claim	Per policy terms, typically within 72 hours	General Counsel
Data protection supervisory authority	Personal data breach likely to result in a risk to individuals	72 hours from awareness (GDPR Art. 33)	Data Protection Officer
Affected individuals	Personal data breach likely to result in high risk to individuals	Without undue delay (GDPR Art. 34)	Data Protection Officer with Communications
Customers and contractual counterparties	As specified in the applicable contract; commonly 24 to 72 hours	Per contract; assessed at triage	Contract Owner with Legal
Sectoral and financial regulators	Per applicable rules for material operational or security incidents	Per applicable rules; often 24 to 72 hours	Compliance
Law enforcement / national CERT	Suspected criminal activity or nationally significant incident	As agreed with Legal Counsel	General Counsel

A notification assessment must be initiated at triage for every SEV 1 and SEV 2 incident and documented even where the conclusion is that no notification is required. The clock for statutory deadlines starts at the point of awareness, not at the point of confirmation.

5.7 Evidence Handling and Forensics

- Evidence is collected in order of volatility: memory, network connections and running processes, then disk, then archived logs.

- Forensic images are acquired using write-blockers or provider-native snapshot mechanisms, hashed on acquisition (SHA-256), and the hash recorded in the chain-of-custody form.
- Chain of custody records who collected each item, when, from where, every transfer, and every access, and is maintained without gaps.
- Evidence is stored encrypted in a segregated evidence repository with access restricted to the investigation team and Legal Counsel.
- Evidence is retained for a minimum of 7 years for SEV 1 and SEV 2 incidents, and longer if subject to legal hold under Section 7.7.
- Analysis is performed on copies. Original images are never mounted read-write.

5.8 Logging and Monitoring Requirements

Log Source	Minimum Events Captured	Online Retention	Archive Retention
Identity provider and directory	Authentication, MFA, authorisation failure, privilege change, federation change	13 months	7 years
Privileged access management	Credential checkout, session start/stop, full session recording	13 months	7 years
Endpoint detection and response	Process execution, persistence, network connections, detections	13 months	3 years
Cloud control plane	All API calls, configuration changes, IAM changes, key operations	13 months	7 years
Network and perimeter	Flow records, DNS, proxy, firewall deny, IDS/IPS alerts	13 months	3 years
Applications handling Restricted data	Authentication, authorisation, data access, export, administrative action	13 months	7 years
Database	Privileged operations, schema change, bulk export	13 months	7 years

Logs must be forwarded to the central platform within 15 minutes, stored immutably, protected against modification by the account that generated them, time-synchronised to an authoritative source, and monitored for ingestion gaps. Loss of logging on a Tier 0 system is a SEV 2 incident.

5.9 Records and Evidence

- Incident records, including timeline, decisions, severity, scope and closure — retained 7 years.
- Post-incident review reports and corrective action tracking — retained 7 years.
- Notification assessments and regulator correspondence — retained 7 years.
- Chain-of-custody forms and forensic artefacts — retained 7 years minimum.
- Exercise and simulation reports — retained 5 years.

5.10 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Mean time to detect (SEV 1 and 2)	≤ 1 hour	> 4 hours
Mean time to acknowledge high-fidelity alerts	≤ 15 minutes	> 30 minutes
Mean time to contain (SEV 1)	≤ 4 hours	> 8 hours

Indicator	Target	Escalation Threshold
Post-incident reviews held within 10 business days	100%	< 90%
Corrective actions closed by due date	≥ 95%	< 85%
Regulatory notifications made within statutory deadline	100%	< 100%
Tier 0 log sources with ingestion gaps > 15 minutes	0	> 0

6. Vendor and Third-Party Security

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.5.19 Information security in supplier relationships; A.5.20 Addressing information security within supplier agreements; A.5.21 Managing information security in the ICT supply chain; A.5.22 Monitoring, review and change management of supplier services; A.5.23 Information security for use of cloud services; A.5.14 Information transfer; A.8.30 Outsourced development
SOC 2 Trust Services Criteria	CC9.2; CC3.2; CC4.1; CC2.3

6.1 Purpose and Scope

This section governs the identification, assessment, contracting, monitoring and termination of third parties that may affect the security of Company or customer information. It applies to suppliers, cloud and SaaS providers, outsourced service providers, professional services firms, agents, resellers and their subcontractors (fourth parties).

Outsourcing a service never outsources accountability. XYZ Corporation remains accountable to its customers and regulators for information handled on its behalf.

6.2 Policy Statements

- VS-01 — No engagement without assessment.** No third party may be granted access to Company information, systems or facilities, and no contract may be executed, before a security risk assessment proportionate to the tier has been completed and approved.
- VS-02 — Central register.** All third parties are recorded in the Third-Party Register with a named Contract Owner, assigned tier, data classifications processed, data locations, subcontractors and assessment status. Engagement of a supplier outside the procurement process (“shadow procurement”) is prohibited.
- VS-03 — Contractual security terms.** Every contract involving Company information must include the mandatory security schedule set out in Section 6.5. Deviations require Legal and CISO approval.
- VS-04 — Right to audit.** Tier 1 and Tier 2 contracts must grant the Company, its regulators and its appointed auditors the right to audit the supplier’s controls relevant to the service, on reasonable notice.
- VS-05 — Fourth-party transparency.** Suppliers must disclose all subcontractors that process Company information, notify the Company at least 30 days before adding or replacing one, and flow down equivalent security obligations.
- VS-06 — Least privilege for third parties.** Third-party access is time-bound, scoped to the minimum required, brokered through the Company’s privileged access solution with session recording, subject to MFA, and revoked automatically at contract or engagement end.
- VS-07 — Continuous monitoring.** Tier 1 and Tier 2 suppliers are subject to continuous external risk monitoring, and to reassessment on the cycle in Section 6.3.
- VS-08 — Incident notification.** Suppliers must notify the Company of any security incident affecting Company information within 24 hours of awareness, and cooperate fully with the Company’s investigation.
- VS-09 — Concentration and exit.** The Company assesses concentration risk across critical suppliers and maintains a documented, tested exit strategy for every Tier 1 supplier, including data return and secure deletion.

VS-10 — Cloud services. Use of cloud services must follow the shared responsibility model documented for each provider, with the Company's responsibilities explicitly assigned to a named owner. Unapproved SaaS is blocked by the cloud access security broker and detected through expense and network analysis.

VS-11 — Software supply chain. Third-party software and open-source components must be sourced from approved repositories, scanned for known vulnerabilities and licence risk, and recorded in a software bill of materials (SBOM) for all Tier 0 and Tier 1 applications.

VS-12 — Artificial intelligence services. Third-party AI and machine-learning services are subject to additional review covering training-data use, model and prompt data retention, output confidentiality, and jurisdiction of processing. Submitting Restricted information to a third-party AI service is prohibited without CISO and DPO approval.

VS-13 — Termination. On termination, all Company data must be returned in an agreed format and then securely deleted, with a signed certificate of destruction provided within 30 days. All access is revoked on or before the last day of service.

6.3 Vendor Tiering and Assessment Depth

Tier	Criteria	Assessment at Onboarding	Reassessment
Tier 1 — Critical	Processes Restricted data; hosts or operates a Tier 0 system; privileged network access; regulatory outsourcing; business-critical dependency with no ready substitute	Full assessment: independent assurance report review (SOC 2 Type II or ISO 27001 certificate with SoA), detailed questionnaire, evidence review, architecture review, on-site or virtual audit, penetration test summary, financial viability and concentration review	Annually, plus on material change
Tier 2 — Significant	Processes Confidential data; system integration without privileged access; material operational dependency	Standard assessment: assurance report review, standard questionnaire, evidence sampling, external risk rating review	Every 18 months
Tier 3 — Limited	Processes Internal data only; no system integration	Light assessment: short questionnaire, attestation, external risk rating	Every 24 months
Tier 4 — Minimal	No access to Company information or systems	Screening questionnaire only to confirm tier	On renewal

Tiering is assigned by the Contract Owner and validated by Third-Party Risk Management. Where a supplier cannot provide an independent assurance report, a direct assessment by the Company is mandatory for Tier 1 and Tier 2 and the residual risk must be formally accepted per Section 1.8.

6.4 Assessment Domains

Tier 1 and Tier 2 assessments must evaluate, at minimum:

- Security governance, organisation, certifications and the scope and exceptions of any assurance report.
- Access control, identity management, privileged access and workforce screening.
- Encryption of data at rest and in transit, and key management.
- Secure development lifecycle, vulnerability management, patching and penetration testing.
- Logging, monitoring and incident response capability, including notification commitments.
- Backup, resilience, business continuity and disaster recovery, including tested RTO and RPO.
- Physical and environmental security of processing locations.
- Data location, cross-border transfer mechanisms, retention and deletion practices.

- Subcontractor management and fourth-party dependencies.
- Personnel security, training and insider threat controls.
- Financial stability, insurance coverage and litigation history.

6.5 Mandatory Contractual Security Schedule

Contracts involving Company information must include, as a minimum:

1. Definition of Company data, confidentiality obligations, and a prohibition on use for any purpose other than delivering the contracted service, including a prohibition on use for model training unless expressly permitted.
2. Specified minimum security controls, referencing this Manual or an agreed equivalent standard.
3. Encryption requirements for data at rest and in transit consistent with Section 3.
4. Security incident notification within 24 hours, with defined content, a named contact and a duty to cooperate.
5. Personal data processing terms, including processor obligations, approved international transfer mechanisms and sub-processor controls.
6. Data location restrictions and a change-notification obligation.
7. Subcontractor disclosure, approval and flow-down of equivalent obligations.
8. Right to audit, and an obligation to provide an annual independent assurance report and remediation plans for exceptions raised in it.
9. Vulnerability management and patching commitments with defined remediation timeframes by severity.
10. Business continuity and disaster recovery commitments, including RTO, RPO and annual test evidence.
11. Return and certified secure deletion of data on termination, with a defined format and timeframe.
12. Liability, indemnity and insurance provisions appropriate to the tier, including cyber liability cover.
13. Compliance with applicable laws, sanctions and export controls.

6.6 Procedures

6.6.1 Onboarding

1. The business sponsor raises a request in the procurement platform describing the service, the data involved and the intended integration.
2. Third-Party Risk Management assigns a tier and issues the corresponding assessment.
3. The supplier completes the assessment and provides supporting evidence. Findings are rated and, where required, a remediation plan with dates is agreed before contract signature.
4. Legal negotiates the security schedule. The CISO approves any material deviation.
5. The Data Protection Officer completes a transfer impact assessment and, where required, a data protection impact assessment.
6. The supplier is added to the Third-Party Register, enrolled in continuous monitoring, and access is provisioned per Section 2 only after contract execution.

6.6.2 Ongoing Monitoring

- External risk ratings and threat intelligence are reviewed monthly for Tier 1 and quarterly for Tier 2; material deterioration triggers an ad hoc reassessment.
- Assurance reports (SOC 2 Type II, ISO 27001) are collected and reviewed annually within 60 days of issuance; qualified opinions, scope limitations and carve-outs are formally assessed and escalated where

material.

- Service level and security performance are reviewed at contractual governance meetings: monthly for Tier 1, quarterly for Tier 2.
- Open findings are tracked to closure by Third-Party Risk Management; overdue Tier 1 findings are escalated to the Steering Committee.
- Material changes — new subcontractors, change of data location, change of control, significant architecture change — trigger reassessment.

6.6.3 Supplier Incident Handling

1. On notification, the Contract Owner immediately raises an incident under Section 5 and engages the Security Operations Centre.
2. The Company determines its own exposure independently rather than relying solely on the supplier's assessment, including reviewing its own logs of supplier activity.
3. Where Company or customer data is affected, the Company's own notification obligations under Section 5.6 apply regardless of the supplier's actions.
4. Post-incident, the supplier's remediation is verified before normal service is resumed, and the supplier's tier and risk rating are reassessed.

6.6.4 Offboarding

1. The Contract Owner initiates offboarding at least 60 days before contract end, or immediately on termination for cause.
2. Data is returned in the contracted format and validated for completeness before deletion is instructed.
3. All logical and physical access is revoked on or before the last service day, verified by Identity and Access Management.
4. Integrations, API keys, certificates and federation trusts are decommissioned.
5. A signed certificate of secure destruction is obtained within 30 days and filed. Failure to provide it is escalated to Legal.
6. The Third-Party Register is updated and the record retained per Section 7.

6.7 Records and Evidence

- Third-Party Register — maintained continuously.
- Assessment questionnaires, evidence, findings and remediation plans — retained 7 years after contract end.
- Assurance reports and review notes — retained 7 years.
- Executed contracts and security schedules — retained 7 years after contract end (or longer where required by law).
- Certificates of data destruction — retained 7 years.

6.8 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Tier 1 suppliers with a current assessment	100%	< 100%
Contracts containing the mandatory security schedule	100%	< 98%
Tier 1 assurance reports reviewed within 60 days of issue	100%	< 90%

Indicator	Target	Escalation Threshold
Overdue Tier 1 remediation findings	0	> 0
Third-party access revoked by last service day	100%	< 100%
Destruction certificates obtained within 30 days	≥ 95%	< 85%

7. Data Retention and Disposal

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.5.33 Protection of records; A.5.34 Privacy and protection of PII; A.5.12 Classification of information; A.5.13 Labelling of information; A.8.10 Information deletion; A.8.11 Data masking; A.7.10 Storage media; A.7.14 Secure disposal or re-use of equipment; A.5.31 Legal, statutory, regulatory and contractual requirements
SOC 2 Trust Services Criteria	C1.1, C1.2; P4.2, P4.3; CC6.5

7.1 Purpose and Scope

This section defines how long XYZ Corporation retains information, how retention is enforced, and how information and the media holding it are securely disposed of. It applies to all information in all formats and locations, including production systems, archives, backups, collaboration platforms, email, endpoints, physical records and third-party systems.

The governing principle is that information is retained only as long as there is a lawful, contractual or demonstrable business reason to retain it, and is then deleted. Over-retention increases breach impact, storage cost and litigation exposure; under-retention creates regulatory and evidential risk.

7.2 Policy Statements

- DR-01 — Retention schedule.** The Company maintains a Records Retention Schedule owned by the General Counsel, defining a retention period and disposition action for every record class. Every information asset must map to a record class.
- DR-02 — Defined trigger.** Each retention period must state its start trigger (for example, creation date, contract end, last customer interaction, employment end) so retention can be enforced systematically.
- DR-03 — Data minimisation.** Personal data is collected only where necessary for a specified purpose, and is deleted or irreversibly anonymised when that purpose is exhausted.
- DR-04 — Automated enforcement.** Retention must be enforced by automated lifecycle policies wherever the platform supports it. Manual deletion processes require a documented control with evidence of execution.
- DR-05 — Deletion means deletion.** Deletion must render information unrecoverable by reasonable means. Logical deletion that leaves recoverable copies in archives, backups, replicas, caches, search indexes, analytics stores or third-party systems does not satisfy this policy; the deletion design must address every copy.
- DR-06 — Legal hold overrides retention.** Information subject to a legal hold must not be deleted, altered or moved, notwithstanding any retention schedule or automated policy. Legal hold takes precedence over all other requirements in this Manual.
- DR-07 — Data subject rights.** Erasure and other data subject requests are handled under the Group Privacy Policy within statutory timeframes, with a documented technical process to locate and delete personal data across all systems.
- DR-08 — Secure disposal of media.** Media holding Restricted or Confidential information must be sanitised or destroyed to NIST SP 800-88 Rev. 1 standards before re-use or disposal, with certificates retained.
- DR-09 — Non-production data.** Production data must not be copied into non-production environments unless masked, tokenised or synthetically generated. Where an exception is approved, the environment must be controlled to production standard and the data deleted within 30 days.

DR-10 — Data residency. Information must be stored and processed only in jurisdictions approved for its classification and data type. Cross-border transfers require an approved transfer mechanism and a transfer impact assessment.

DR-11 — Defensible disposition. Disposal is executed under a documented, consistently applied process with evidence retained, so that the Company can demonstrate that disposal was routine and in good faith.

DR-12 — Ownership. Every record class has a named Information Asset Owner accountable for confirming that retention is correctly applied, reviewed annually.

7.3 Baseline Retention Schedule

The following baseline applies where no more specific legal, regulatory or contractual requirement exists. Where requirements conflict, the longest applicable period governs, and the conflict is recorded in the Records Retention Schedule.

Record Class	Retention Period	Trigger	Disposition
Customer contracts and commercial agreements	7 years	Contract end	Secure destruction
Customer transaction and account records	7 years	Account closure	Secure destruction
Financial and accounting records, tax records	7 years (10 where local law requires)	End of financial year	Secure destruction
Employee records	7 years	End of employment	Secure destruction
Recruitment records for unsuccessful candidates	12 months	Decision date	Secure destruction
Marketing consent and preference records	Duration of relationship plus 3 years	Last interaction or withdrawal	Secure destruction
Security and audit logs (Tier 0 / Restricted systems)	7 years	Event date	Automated purge
Security and audit logs (other systems)	3 years	Event date	Automated purge
Incident records and forensic evidence	7 years	Incident closure	Secure destruction subject to hold
Access request, approval and review records	7 years	Record creation	Automated purge
CCTV and physical access logs	90 days (CCTV); 2 years (badge logs)	Recording date	Automated purge
Corporate email and instant messaging	3 years	Message date	Automated purge subject to hold
Board and committee minutes	Permanent	n/a	Archive
Policies, standards and ISMS documentation	7 years after superseded	Supersession	Archive then destruction
Third-party assessments and assurance reports	7 years	Contract end	Secure destruction
Training completion records	5 years	Completion date	Secure destruction

Record Class	Retention Period	Trigger	Disposition
Backup sets	Per Section 4.3 tier schedule	Backup date	Automated expiry

7.4 Procedures

7.4.1 Applying Retention to a New System

1. At design stage, the System Owner identifies the record classes the system will hold and maps them to the Records Retention Schedule.
2. The design must specify how deletion will be executed across the primary store, replicas, caches, search indexes, analytics pipelines, exports, backups and any third-party system.
3. Automated lifecycle policies are configured and tested before go-live. Systems that cannot enforce retention require an exception under Section 1.8 with a documented compensating manual process.
4. Retention configuration is recorded in the Data Inventory and reviewed at the annual asset owner attestation.

7.4.2 Routine Disposition

1. Automated lifecycle jobs execute on schedule and produce a disposition log recording record class, volume, date and method.
2. Where the schedule requires review before destruction, the Information Asset Owner reviews and approves the disposition list, confirming no legal hold applies.
3. Legal hold status is verified programmatically against the Legal Hold Register immediately before any destruction event; a positive hold suppresses deletion and raises a notification.
4. Disposition logs are retained as evidence of defensible disposition.

7.4.3 Handling an Erasure Request

1. The request is logged and the identity of the requester verified before any action.
2. The Data Protection Officer confirms the request is valid and assesses whether an exemption applies, including legal hold, legal obligation, or establishment or defence of legal claims.
3. Systems holding the individual's personal data are identified from the Data Inventory, and deletion or anonymisation is executed across all of them, including third-party processors.
4. Where data persists in backups pending expiry, it is placed beyond use — excluded from restoration and re-deletion applied if restored — and this is explained to the requester.
5. Completion is confirmed to the requester within the statutory deadline and the record retained as evidence.

7.5 Legal Hold

1. Legal Counsel issues a legal hold notice when litigation, regulatory investigation or an internal investigation is reasonably anticipated.
2. The hold is recorded in the Legal Hold Register with scope, custodians, data sources, date ranges and the issuing counsel.
3. Custodians acknowledge the notice in writing; acknowledgements are tracked and chased until complete.
4. IT applies technical preservation to the identified sources, suspending retention policies, automated deletion, backup expiry and mailbox purges within scope.

5. Holds are reviewed at least quarterly by Legal Counsel and released formally in writing when no longer required, at which point normal retention resumes and any resulting disposition is executed.

7.6 Secure Disposal Methods

Media / Asset Type	Restricted and Confidential	Internal
Self-encrypting drives and cloud volumes	Cryptographic erase (destroy the key) plus verification, per NIST SP 800-88 Purge	Cryptographic erase
Solid-state drives	Cryptographic erase plus vendor sanitise command; physical destruction (shred to ≤ 2 mm) if leaving Company control	Sanitise command
Magnetic hard drives	Degauss or physically shred if leaving Company control; multi-pass overwrite for internal re-use	Single-pass overwrite
Backup tapes	Degauss and shred	Degauss
Removable media (USB, optical)	Physical destruction	Physical destruction
Mobile devices	Remote wipe, factory reset with crypto erase, then destruction if end of life	Factory reset
Paper records	Cross-cut shredding to DIN 66399 level P-5 or secure destruction bin with certificate	Cross-cut shredding
Multifunction devices and printers	Sanitise or remove and destroy internal storage before disposal or lease return	Sanitise storage
Cloud object and database storage	Delete plus crypto-shred the encrypting key; confirm replica and snapshot deletion	Delete with lifecycle policy

Disposal performed by a third party requires a contracted, certified destruction vendor operating under chain of custody, with a serialised certificate of destruction obtained for every batch. Certificates are reconciled against the asset register within 30 days of collection.

7.7 Records and Evidence

- Records Retention Schedule and version history — retained 7 years after supersession.
- Data Inventory including record class mapping and retention configuration — maintained continuously.
- Disposition logs — retained 7 years.
- Legal Hold Register, notices and acknowledgements — retained 7 years after release.
- Certificates of destruction and asset disposal reconciliations — retained 7 years.
- Erasure request records and completion evidence — retained per the Group Privacy Policy.

7.8 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Systems with automated retention enforcement	$\geq 95\%$	$< 85\%$
Data past defined retention still held	0	$> 2\%$ of records
Legal hold acknowledgements obtained within 5 business days	100%	$< 95\%$
Destruction certificates reconciled within 30 days	100%	$< 90\%$

Indicator	Target	Escalation Threshold
Non-production environments holding unmasked production data	0	> 0
Erasure requests completed within statutory deadline	100%	< 100%

8. Security Awareness and Training

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.6.3 Information security awareness, education and training; A.6.1 Screening; A.6.2 Terms and conditions of employment; A.6.4 Disciplinary process; A.6.5 Responsibilities after termination or change of employment; A.6.6 Confidentiality or non-disclosure agreements; A.5.4 Management responsibilities; A.8.28 Secure coding
SOC 2 Trust Services Criteria	CC1.1, CC1.4, CC1.5; CC2.2; CC5.3

8.1 Purpose and Scope

This section establishes how XYZ Corporation ensures that all Personnel understand their information security responsibilities, are competent to discharge them, and behave in a manner consistent with the Company’s risk appetite. It applies to all Personnel and, where specified, to third-party staff with access to Company systems.

8.2 Policy Statements

- SA-01 — Mandatory induction.** All Personnel must complete security induction training before, or within five business days of, being granted access to Company systems. Access is suspended if not completed within 15 business days.
- SA-02 — Annual refresher.** All Personnel must complete annual security and privacy refresher training. Completion is a condition of continued system access and is a factor in annual performance review.
- SA-03 — Role-based training.** Personnel in roles with elevated security responsibility must complete additional role-specific training as set out in Section 8.5, at the stated frequency.
- SA-04 — Continuous simulation.** The Company operates a continuous phishing and social engineering simulation programme covering all Personnel, with immediate point-of-failure coaching.
- SA-05 — Acceptable Use.** All Personnel must acknowledge the Acceptable Use Policy at induction and at each annual refresher. Acknowledgement records are retained as evidence.
- SA-06 — Screening.** Background screening proportionate to the role must be completed before access is granted, in accordance with local law. Roles with access to Restricted data or privileged access require enhanced screening, re-verified every three years.
- SA-07 — Confidentiality agreements.** All Personnel and third-party staff must be bound by confidentiality obligations that survive termination. Obligations are reaffirmed at exit.
- SA-08 — Management responsibility.** Line managers are accountable for their team’s training completion and for reinforcing secure behaviour. Team completion rates are reported to managers monthly and to the Executive Committee quarterly.
- SA-09 — Positive reporting culture.** The Company measures and rewards reporting of suspicious activity. Reporting rate is treated as a leading indicator of programme health, alongside failure rate.
- SA-10 — Disciplinary process.** A formal, communicated disciplinary process applies to security policy violations, applied consistently and proportionately, and is documented in the Employee Handbook.
- SA-11 — Exit obligations.** At termination, Personnel are reminded in writing of continuing confidentiality obligations, and must return all Company information and assets.

SA-12 — Effectiveness measurement. The programme is measured on behavioural outcomes, not only completion. Content is revised at least annually and after any incident that reveals a knowledge or behaviour gap.

8.3 Core Curriculum

The annual mandatory curriculum for all Personnel covers, at minimum:

- Information classification, handling and labelling requirements (Section 1.4).
- Phishing, vishing, smishing, business email compromise, deepfake and AI-assisted social engineering, and multi-factor authentication fatigue attacks.
- Password and credential hygiene, passkey use, and the prohibition on credential sharing and reuse.
- Acceptable use of Company systems, email, internet, collaboration platforms and generative AI tools.
- Clear desk and clear screen, physical security, tailgating and visitor management.
- Remote and hybrid working, home network security, public Wi-Fi and shoulder surfing.
- Mobile device and removable media security.
- Data protection principles, lawful handling of personal data, and recognising a personal data breach.
- How, when and to whom to report a suspected security event, and the no-blame reporting commitment (Section 5.3 IR-02).
- Insider risk indicators and how to raise a concern, including confidential whistleblowing channels.
- Consequences of non-compliance and the disciplinary process.

8.4 Delivery Model

Channel	Audience	Frequency	Purpose
Induction module	All new Personnel	On joining	Establish baseline obligations before access
Annual refresher module	All Personnel	Annually	Refresh core curriculum; capture acknowledgements
Micro-learning	All Personnel	Monthly, 5–10 minutes	Reinforce single behaviours; respond to emerging threats
Phishing simulation	All Personnel	At least monthly, randomised	Measure and improve resistance to social engineering
Role-based deep dives	Elevated-risk roles	Per Section 8.5	Build role-specific competence
Executive briefings	Executive Committee and Board	Quarterly	Threat landscape, risk posture, decision readiness
Security champions network	Nominated representatives in each function	Monthly forum	Embed security in delivery teams; local escalation point
Awareness campaigns	All Personnel	Quarterly themes	Sustained focus on priority risks
Just-in-time coaching	Individuals who fail a simulation or trigger a policy control	On event	Immediate, contextual correction

8.5 Role-Based Training Requirements

Role	Additional Training	Frequency
Software engineers and architects	Secure coding, OWASP Top 10, threat modelling, secure use of AI coding assistants, secrets management	Annually, with hands-on assessment
System, cloud and database administrators	Secure configuration, privileged access handling, hardening baselines, logging integrity	Annually
Security Operations Centre analysts	Detection engineering, forensics, threat hunting, incident handling certification pathway	Continuous, minimum 40 hours per year
Incident response team members	Incident command, evidence handling, crisis communication; participation in exercises	Semi-annually
Executives and Board members	Cyber risk governance, crisis decision-making, personal targeting and executive impersonation risk	Annually plus quarterly briefing
HR and Recruitment	Screening obligations, handling employee personal data, insider risk indicators	Annually
Finance and Accounts Payable	Payment fraud, business email compromise, invoice redirection, callback verification procedures	Semi-annually
Procurement and Contract Owners	Third-party risk process, mandatory security schedule, supplier incident handling	Annually
Customer support and service desk	Caller verification, social engineering resistance, handling customer personal data	Semi-annually
Privileged access holders	Privileged session handling, break-glass procedures, change discipline	Annually

8.6 Phishing Simulation Programme

1. Simulations are run at least monthly against randomised population segments, with difficulty calibrated to observed threat actor tradecraft and increasing over the year.
2. Executive, finance and privileged-access populations receive targeted, higher-sophistication simulations reflecting real spear-phishing risk.
3. Individuals who interact with a simulation receive immediate in-context coaching and an assigned micro-module.
4. Repeat failure escalates: first failure triggers coaching; second within 12 months triggers a manager conversation and additional training; third triggers a formal review with HR and may result in restriction of email attachment and link handling privileges.
5. Simulation data is used for programme improvement and is not used punitively as an isolated performance metric. Individual results are shared with line managers only from the second failure onward.
6. Reporting rate is measured alongside failure rate; a high reporting rate is the primary success measure.

8.7 Procedures

8.7.1 Onboarding

1. HR triggers enrolment in the learning platform on creation of the worker record.
2. Background screening is completed and cleared before access provisioning (Section 2.4.1).
3. The individual signs the Acceptable Use Policy, confidentiality agreement and, where applicable, the Privileged User Agreement.

- Induction training is completed within five business days; automated reminders issue at days 3, 5 and 10, with access suspension at day 15.

8.7.2 Non-Completion Escalation

Elapsed Time Past Due	Action
Day 1	Automated reminder to the individual
Day 7	Reminder to the individual copied to the line manager
Day 14	Escalation to the manager's manager; individual listed in the functional compliance report
Day 21	Escalation to the accountable Executive Committee member; system access suspended pending completion
Day 30	Referred to HR under the disciplinary process

8.7.3 Offboarding

- The exit interview includes a documented reminder of continuing confidentiality and non-disclosure obligations.
- The departing individual confirms in writing the return of all Company information and assets, and the deletion of Company data from any personal device.
- Access is revoked per Section 2.4.3.

8.8 Records and Evidence

- Training completion records by individual, module and date — retained 5 years.
- Acceptable Use Policy and confidentiality agreement acknowledgements — retained 7 years after employment ends.
- Background screening records — retained per local law, held by HR with restricted access.
- Phishing simulation results and coaching records — retained 3 years.
- Exit acknowledgement records — retained 7 years.
- Curriculum versions and annual content review records — retained 5 years.

8.9 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Induction training completed before or within 5 days of access	≥ 98%	< 95%
Annual refresher completion	≥ 98% by year end	< 95%
Role-based training completion for elevated-risk roles	100%	< 95%
Phishing simulation failure rate	≤ 3%	> 8%
Phishing simulation reporting rate	≥ 70%	< 50%
Median time to report a real phishing email	≤ 10 minutes	> 60 minutes
Repeat simulation failures (3+ in 12 months)	≤ 1% of population	> 3%

9. Disaster Recovery and Business Continuity

CONTROL ALIGNMENT	
ISO/IEC 27001:2022 Annex A	A.5.29 Information security during disruption; A.5.30 ICT readiness for business continuity; A.8.14 Redundancy of information processing facilities; A.8.13 Information backup; A.7.5 Protecting against physical and environmental threats; A.7.11 Supporting utilities; A.5.24 Incident management planning
SOC 2 Trust Services Criteria	A1.1, A1.2, A1.3; CC7.5; CC9.1

9.1 Purpose and Scope

This section defines how XYZ Corporation prepares to continue delivering critical business services during a disruption and to recover technology services following a disaster. It applies to all business processes and to all technology services supporting them, including those delivered by third parties.

Disaster recovery (DR) addresses the recovery of technology; business continuity (BC) addresses the continuation of business processes, including by manual workaround. Both are required; neither alone is sufficient.

9.2 Policy Statements

- BC-01 — Business impact analysis.** A business impact analysis (BIA) is conducted at least annually for every business process, establishing maximum tolerable period of disruption, recovery time objective (RTO), recovery point objective (RPO) and minimum business continuity objective.
- BC-02 — Documented plans.** Every critical business service has a documented, current business continuity plan; every supporting technology service has a documented, current disaster recovery plan with step-by-step recovery runbooks.
- BC-03 — Recovery objectives are designed, not aspirational.** Architecture must be capable of meeting the stated RTO and RPO, evidenced by test results. Where it cannot, the gap is recorded as a risk and either remediated or formally accepted under Section 1.8.
- BC-04 — Geographic separation.** Recovery capability for Tier 0 and Tier 1 services must reside in a separate availability zone and, for Tier 0, a separate region or geographically distinct site, with independent power, network and cooling.
- BC-05 — No shared single point of failure.** The recovery environment must not depend on any single component, credential store, identity provider or network path shared with the primary environment in a way that would fail simultaneously.
- BC-06 — Security controls apply in recovery.** All controls in this Manual apply equally in the recovery environment and during a disruption. Degraded operation must not be used as justification to bypass access control, encryption or logging.
- BC-07 — Testing.** Plans must be tested to the schedule in Section 9.5. An untested plan is treated as no plan.
- BC-08 — Crisis management.** A standing Crisis Management Team with defined membership, delegated authority and documented activation criteria is maintained and exercised annually.
- BC-09 — Dependency mapping.** Service dependency maps, including third-party and fourth-party dependencies, are maintained and reviewed at least annually and after material change.

BC-10 — Third-party resilience. Suppliers supporting critical services must evidence tested continuity capability meeting the Company's RTO and RPO, per Section 6.4.

BC-11 — People resilience. Key roles must have identified and trained deputies. Succession and single-person-dependency risks are reviewed annually.

BC-12 — Plan currency. Plans are reviewed and updated at least annually, and after any material architecture change, organisational change, test or actual invocation.

9.3 Service Tiering and Recovery Objectives

Tier	Definition	RTO	RPO	Resilience Pattern
Tier 0 — Mission critical	Loss causes immediate severe customer, financial or regulatory impact	≤ 1 hour	≤ 15 minutes	Active-active across regions with automated failover
Tier 1 — Business critical	Loss causes material impact within one business day	≤ 4 hours	≤ 1 hour	Active-passive warm standby with tested failover
Tier 2 — Business important	Loss tolerable for up to three business days	≤ 24 hours	≤ 4 hours	Pilot light or rapid rebuild from infrastructure as code
Tier 3 — Standard	Loss tolerable for more than three business days	≤ 5 business days	≤ 24 hours	Restore from backup

Tier assignment is made by the Information Asset Owner through the BIA, validated by the CIO and CISO, and recorded in the Service Catalogue. Recovery objectives for a service may not be weaker than those of any service that depends on it.

9.4 Plan Content Requirements

Each disaster recovery plan must contain:

- Service description, tier, RTO, RPO and business owner.
- Architecture diagram covering primary and recovery environments, and the full upstream and downstream dependency map.
- Activation criteria, the named individuals authorised to invoke, and the invocation procedure.
- Roles, responsibilities and the contact tree, including deputies and out-of-hours contacts.
- Step-by-step recovery runbook, executable by a competent engineer who did not write it.
- Data recovery procedure and its dependency on the backups defined in Section 4.
- Validation and acceptance criteria for declaring the service recovered.
- Communication plan for internal stakeholders, customers, suppliers and, where relevant, regulators.
- Failback procedure to return to normal operations.
- Known limitations, assumptions and open risks.
- Version, owner, last review date and last test date.

9.5 Testing Programme

Test Type	Description	Scope	Frequency
Plan walkthrough	Desk review of the plan for accuracy and currency	All plans	Annually

Test Type	Description	Scope	Frequency
Tabletop exercise	Facilitated scenario discussion with decision-makers	All Tier 0 and Tier 1 services	Semi-annually
Component failover test	Failover of an individual component or zone in production or a production-like environment	Tier 0 and Tier 1	Quarterly
Full service failover	Complete failover of the service to the recovery environment with live traffic	Tier 0	Semi-annually
Regional failover	Failover of the full Tier 0 estate to an alternate region	Tier 0 estate	Annually
Backup restore test	Per Section 4.5	Per Section 4.5	Per Section 4.5
Crisis management exercise	Executive-level simulation including communications and regulatory decision-making	Crisis Management Team and Executive Committee	Annually
Third-party joint exercise	Coordinated exercise with critical suppliers	Tier 1 suppliers supporting Tier 0 services	Annually

Every test must record the achieved RTO and RPO against target, defects identified, and corrective actions with owners and due dates. A test that fails to meet its objectives is a control failure, requiring root cause analysis within 10 business days and a successful re-test within 90 days. Test reports are retained as ISO 27001 and SOC 2 evidence.

9.6 Procedures

9.6.1 Invocation

- Any incident meeting the activation criteria is escalated to the accountable Service Owner and the Incident Commander.
- The Incident Commander, with the Service Owner, decides whether to invoke DR. For Tier 0 services and for any invocation with customer impact, the Crisis Management Team is convened and the CIO or CISO authorises invocation.
- The decision, its time and its rationale are recorded. Delay in deciding is itself a risk; where the RTO would be breached by continued diagnosis, the default is to invoke.
- Stakeholders are notified per the communication plan, and customer-facing status communications are issued through the approved channel by Communications.

9.6.2 Recovery Execution

- The recovery team executes the runbook, recording each step, its completion time and any deviation.
- Data is recovered per Section 4, and the achieved recovery point is confirmed with the business owner before service is exposed to users.
- Security controls in the recovery environment are verified before service resumption: access control, encryption, logging and monitoring.
- The Service Owner confirms against the validation criteria and formally declares the service recovered.

9.6.3 Failback and Closure

- Failback to the primary environment is planned as a change, executed in a controlled window, and must not itself risk data loss; data written in the recovery environment must be reconciled.
- A post-invocation review is held within 10 business days, following the process in Section 5.5.7.

3. Plans, runbooks and dependency maps are updated to reflect what was learned.
4. Actual RTO and RPO achieved are reported to the Steering Committee and, for Tier 0 invocations, to the Risk Committee.

9.7 Environmental and Physical Resilience

- Facilities housing information processing equipment must have redundant power (UPS and generator with contracted fuel supply), redundant cooling, and redundant diverse network paths.
- Fire detection and suppression appropriate to the equipment, water detection, and environmental monitoring with alerting must be installed and tested annually.
- Supporting utilities are inspected and tested to manufacturer schedules; generator load tests are conducted at least quarterly.
- Site selection considers flood, seismic, wildfire and civil disruption risk, and is reassessed at lease renewal.
- Where the Company relies on a colocation or cloud provider for these controls, evidence of their effectiveness is obtained through the assurance process in Section 6.

9.8 Records and Evidence

- Business impact analyses — retained 7 years.
- Business continuity and disaster recovery plans, all versions — retained 7 years after supersession.
- Test plans, results and corrective action tracking — retained 7 years.
- Invocation records, decision logs and post-invocation reviews — retained 7 years.
- Dependency maps and Service Catalogue tiering — maintained continuously.

9.9 Key Performance and Risk Indicators

Indicator	Target	Escalation Threshold
Tier 0 and Tier 1 services with a current, tested plan	100%	< 100%
Tests achieving stated RTO	≥ 95%	< 85%
Tests achieving stated RPO	100%	< 95%
Plans reviewed within the last 12 months	100%	< 95%
Corrective actions from tests closed by due date	≥ 95%	< 85%
Critical suppliers with evidenced tested continuity capability	100%	< 90%
Unplanned Tier 0 downtime against availability commitment	Within commitment	Breach of commitment

10. Assurance, Monitoring and Continual Improvement

10.1 Three Lines Model

Line	Function	Responsibility
First line	Business and technology operations	Own and operate controls; perform quarterly control self-assessment; remediate deficiencies.
Second line	Information Security, Risk, Compliance, Privacy	Set policy and standards; monitor control performance; challenge the first line; maintain the risk register.
Third line	Internal Audit	Provide independent assurance to the Audit Committee over the design and operating effectiveness of controls.

10.2 Assurance Calendar

Activity	Frequency	Owner
Automated continuous control monitoring	Continuous	Security Engineering
Control self-assessment	Quarterly	Control owners
Vulnerability scanning (external and internal)	Weekly, with authenticated scans monthly	Security Operations
Penetration testing of internet-facing services	Annually, and before major release	CISO
Red team exercise	Annually	CISO
ISMS internal audit programme	Rolling annual coverage of all Annex A controls in scope	Internal Audit / ISMS Manager
SOC 2 Type II examination	Annually, 12-month observation period	Compliance
ISO 27001 surveillance / recertification audit	Annual surveillance; recertification every 3 years	ISMS Manager
Management review of the ISMS	Semi-annually	CISO with Executive Committee
Risk assessment refresh	Annually, and on material change	Risk Management
Policy review and re-approval	Annually	CISO

10.3 Deficiency Management

- Control deficiencies from any source — monitoring, self-assessment, audit, incident, test or third-party assessment — are recorded in a single issues register with a severity rating, owner and due date.
- Remediation timeframes are: Critical, 15 days; High, 30 days; Medium, 90 days; Low, 180 days.
- Overdue Critical and High deficiencies are escalated to the CISO weekly and to the Steering Committee monthly. Deficiencies overdue by more than 60 days are reported to the Risk Committee.
- Closure requires evidence of remediation validated by a party independent of the remediating team.

10.4 Reporting

- Weekly: operational security metrics and open Critical/High deficiencies to the CISO.
- Monthly: control performance dashboard, incident summary and programme status to the Executive Committee.
- Quarterly: risk posture, key indicators against target, exception register, third-party risk and assurance results to the Information Security Steering Committee and the Risk Committee.
- Annually: ISMS management review, including audit results, incident trends, objective performance, resource adequacy and improvement opportunities.

Appendix A — Framework Control Mapping

The table below maps each section of this Manual to the ISO/IEC 27001:2022 Annex A controls and AICPA SOC 2 Trust Services Criteria it primarily addresses. It is a summary; the authoritative and complete mapping is the Statement of Applicability maintained by the ISMS Manager.

Manual Section	ISO/IEC 27001:2022 Annex A	SOC 2 Trust Services Criteria
1. Introduction and Governance	A.5.1, A.5.2, A.5.4, A.5.8, A.5.12, A.5.13, A.5.31, A.5.35, A.5.36, A.5.37	CC1.1–CC1.5, CC2.1–CC2.3, CC3.1–CC3.4, CC5.1–CC5.3
2. Access Control	A.5.3, A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.4, A.8.5, A.8.18	CC6.1, CC6.2, CC6.3, CC6.6, CC6.8
3. Encryption and Cryptographic Controls	A.8.24, A.5.17, A.5.33, A.8.12, A.8.20, A.8.21, A.8.26, A.7.10	CC6.1, CC6.6, CC6.7, C1.1
4. Backups	A.8.13, A.8.14, A.5.33, A.5.29, A.7.10, A.8.24	A1.2, A1.3, CC7.5, C1.1
5. Incident Response	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28, A.6.8, A.5.5, A.5.6, A.8.15, A.8.16	CC7.1, CC7.2, CC7.3, CC7.4, CC7.5, CC2.2, CC2.3, CC4.2
6. Vendor and Third-Party Security	A.5.19, A.5.20, A.5.21, A.5.22, A.5.23, A.5.14, A.8.30	CC9.2, CC3.2, CC4.1, CC2.3
7. Data Retention and Disposal	A.5.33, A.5.34, A.5.12, A.5.13, A.8.10, A.8.11, A.7.10, A.7.14, A.5.31	C1.1, C1.2, P4.2, P4.3, CC6.5
8. Security Awareness and Training	A.6.1, A.6.2, A.6.3, A.6.4, A.6.5, A.6.6, A.5.4, A.8.28	CC1.1, CC1.4, CC1.5, CC2.2, CC5.3
9. Disaster Recovery and Business Continuity	A.5.29, A.5.30, A.8.14, A.8.13, A.7.5, A.7.11, A.5.24	A1.1, A1.2, A1.3, CC7.5, CC9.1
10. Assurance and Continual Improvement	A.5.35, A.5.36, A.8.8, A.8.16, A.8.34	CC4.1, CC4.2, CC3.1, CC5.1

Note: ISO/IEC 27001:2022 Annex A comprises 93 controls across four themes: A.5 Organizational (37), A.6 People (8), A.7 Physical (14) and A.8 Technological (34). SOC 2 criteria references follow the 2017 Trust Services Criteria with the 2022 revised points of focus. Physical security (A.7), operations security, vulnerability and change management, secure development (A.8) and human resource security beyond awareness are addressed in companion Level 2 and Level 3 documents referenced in Section 1.6.

Appendix B — Glossary

Term	Definition
Air gap	Physical or logical isolation of a system or backup copy such that it cannot be reached over a network from the production environment.
BIA	Business Impact Analysis. Assessment of the consequences of disruption to a business process over time, used to derive recovery objectives.
Break-glass	A pre-authorised emergency credential or procedure used only when normal access paths are unavailable.
CSPRNG	Cryptographically Secure Pseudo-Random Number Generator.
Cryptoperiod	The defined time span during which a specific key is authorised for use.
Crypto-shredding	Rendering encrypted data unrecoverable by securely destroying the encryption key.
DFIR	Digital Forensics and Incident Response.
EDR	Endpoint Detection and Response.
HSM	Hardware Security Module. A tamper-resistant device for generating, storing and using cryptographic keys.
Immutable backup	A backup copy that cannot be modified or deleted before its retention lock expires, by any account.
ISMS	Information Security Management System, as defined by ISO/IEC 27001.
JIT access	Just-in-Time access. Privileges granted for a bounded period against an approved request and automatically revoked.
Legal hold	A directive to preserve information relevant to anticipated or actual litigation or investigation, overriding retention schedules.
MFA	Multi-Factor Authentication.
Non-human identity	A service account, API key, token, certificate or workload identity used by software rather than a person.
Personal data	Any information relating to an identified or identifiable natural person.
Phishing-resistant MFA	Authentication bound to the origin such that credentials cannot be relayed to an attacker-controlled site; typically FIDO2/WebAuthn.
PII	Personally Identifiable Information.
RPO	Recovery Point Objective. The maximum acceptable amount of data loss, measured in time.
RTO	Recovery Time Objective. The maximum acceptable duration of service unavailability.
SBOM	Software Bill of Materials. A formal inventory of components in a software product.
SIEM	Security Information and Event Management platform.
SoA	Statement of Applicability. The ISO 27001 document recording which Annex A controls apply and why.
SOC	Security Operations Centre (in the context of monitoring), or System and Organization Controls (in the context of SOC 2 reporting). Meaning is indicated by context.
Toxic combination	A set of entitlements that together create an unacceptable segregation-of-duties conflict.

Term	Definition
Zero Trust	A security model that assumes no implicit trust based on network location and verifies identity, device and context on every access request.

Appendix C — Document Control and Revision History

C.1 Document Control

Attribute	Value
Document title	XYZ Corporation Information Security Manual
Document reference	XYZ-ISMS-MAN-001
Version	1.0
Classification	Internal
Document owner	Chief Information Security Officer
Approver	Chief Executive Officer, on the recommendation of the Information Security Steering Committee
Effective date	31 July 2026
Next scheduled review	31 July 2027
Review frequency	Annually, or upon material change
Distribution	All Personnel via the Company policy portal; third parties on request under NDA

C.2 Revision History

Version	Date	Author	Summary of Change	Approved By
0.1	—	Security Governance	Initial draft for internal review	—
0.2	—	Security Governance	Incorporated Legal, Privacy and Internal Audit comments	—
0.9	—	CISO	Steering Committee review draft	Steering Committee
1.0	31 July 2026	CISO	First approved issue covering access control, encryption, backups, incident response, vendor security, data retention, security awareness and disaster recovery, mapped to ISO/IEC 27001:2022 Annex A and SOC 2 Trust Services Criteria	Chief Executive Officer

C.3 Related Documents

- XYZ-ISMS-POL-001 — Information Security Policy (Level 1)
- XYZ-ISMS-SOA-001 — Statement of Applicability
- XYZ-ISMS-STD-004 — Cryptographic Standard
- XYZ-ISMS-STD-011 — Cloud Security Baseline
- XYZ-ISMS-PLN-002 — Incident Response Plan
- XYZ-ISMS-PLN-005 — Crisis Management Plan

- XYZ-LEG-SCH-001 — Records Retention Schedule
- XYZ-HR-POL-007 — Acceptable Use Policy
- XYZ-PRV-POL-001 — Group Privacy Policy
- XYZ-PRC-STD-003 — Third-Party Risk Management Standard